CVEs más relevantes de la semana

Del 31/10/2026 al 07/11/2026

Porque el primer paso para defender es conocer las amenazas.



CVE-2026-86596

Descripción: The s2Member plugin for WordPress is vulnerable to Remote Code Execution in all versions up to, and including, <= 260927 via the 'item_name' parameter parameter. This is due to insufficient sanitization in strip_php_tags_deep(), which only strips literal '<?' sequences, combined with a post-interpolation placeholder cleanup that reassembles a valid '<?php' opener after the attacker-controlled v...

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-94

Tecnología: No especificado

Publicado el: 2026-11-02

CVE-2026-121597

Descripción: A weakness has been identified in TOTOLINK A950RG 4.1.2cu.5268_B20221104. This affects the function setAppEasyWizardConfig of the file /cgi-bin/cstecgi.cgi of the component Easy Setup Wizard Handler. Executing a manipulation of the argument functionType can lead to stack-based buffer overflow. The attack may be performed from remote. The exploit has been made available to the public and could b...

CVSS: 9.9 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:C/C:H/I:H/A:H

Tipo: CWE-119

Tecnología: No especificado

Publicado el: 2026-11-04

CVE-2026-121600

Descripción: A flaw has been found in TOTOLINK A950RG 4.1.2cu.5268_B20221104. Affected by this vulnerability is the function setMacFilterRules of the file /cgi-bin/cstecgi.cgi of the component MAC Filter Handler. This manipulation of the argument addEffect causes stack-based buffer overflow. The attack can be initiated remotely. The exploit has been published and may be used.

CVSS: 9.9 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:C/C:H/I:H/A:H

Tipo: CWE-119

Tecnología: No especificado

Publicado el: 2026-11-04

CVE-2026-121606

Descripción: A vulnerability has been found in Qihoo 360 D621-2, D603-2, D600-2, D619, D606-6 and D706 up to 6.4.9. Affected by this issue is the function verify_sign of the file fs2/bin/iscm of the component Firmware Signature Verification. Such manipulation of the argument sign leads to improper verification of cryptographic signature. The attack can be launched remotely. The exploit has been disclosed to...

CVSS: 10.0 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:H

Tipo: CWE-345

Tecnología: No especificado

Publicado el: 2026-11-04



CVE-2026-121607

Descripción: A vulnerability was found in Qihoo 360 D603-2, D600-2, D606-6 and D706 up to 6.4.9. This affects the function testspeed_command of the file /fs2/bin/iscm. Performing a manipulation of the argument host results in os command injection. The attack may be initiated remotely. The exploit has been made public and could be used. The vendor was contacted early about this disclosure but did not respond...

CVSS: 10.0 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:H

Tipo: CWE-77

Tecnología: No especificado

Publicado el: 2026-11-04

CVE-2026-121609

Descripción: A vulnerability was identified in Qihoo 360 Whole Home Router M5 4.0.17.1566. This issue affects the function Home of the file /etc/init.d/mpt of the component Boot Script. The manipulation leads to hard-coded credentials. Remote exploitation of the attack is possible. The exploit is publicly available and might be used. The vendor was contacted early about this disclosure but did not respond i...

CVSS: 10.0 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:H

Tipo: CWE-259

Tecnología: No especificado

Publicado el: 2026-11-04

CVE-2026-121615

Descripción: A vulnerability was determined in Linksys E5600 1.1.0.26. Affected is an unknown function of the file /cgi-bin/mesh_login.cgi of the component Login Handler. Executing a manipulation can lead to improper authentication. The attack can be launched remotely. The exploit has been publicly disclosed and may be utilized. The vendor was contacted early about this disclosure but did not respond in any...

CVSS: 10.0 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:H

Tipo: CWE-287

Tecnología: No especificado

Publicado el: 2026-11-04

CVE-2026-121930

Descripción: A weakness has been identified in Linksys WRT54GL 4.30.18. The affected element is the function system of the file apply.cgi of the component Ping Diagnostic. This manipulation of the argument ping_ip causes os command injection. The attack can be initiated remotely. The exploit has been made available to the public and could be used for attacks. The vendor was contacted early about this disclo...

CVSS: 9.1 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:H/UI:N/S:C/C:H/I:H/A:H

Tipo: CWE-77

Tecnología: No especificado

Publicado el: 2026-11-04

CVE-2026-121931

Descripción: A security vulnerability has been detected in Linksys WRT54GL 4.30.18. The impacted element is the function system of the file apply.cgi of the component Traceroute Diagnostic Function. Such manipulation of the argument traceroute_ip leads to os command injection. The attack can be launched remotely. The exploit has been disclosed publicly and may be used. The vendor was contacted early about t...

CVSS: 9.1 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:H/UI:N/S:C/C:H/I:H/A:H

Tipo: CWE-77

Tecnología: No especificado

Publicado el: 2026-11-04

CVE-2026-121932

Descripción: A vulnerability was detected in Linksys E5350 1.0.00.037. This affects the function system of the file /wizard/apply.cgi. Performing a manipulation of the argument ping_ip/traceroute_ip results in os command injection. The attack may be initiated remotely. The exploit is now public and may be used. The vendor was contacted early about this disclosure but did not respond in any way.

CVSS: 10.0 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:H

Tipo: CWE-77

Tecnología: No especificado

Publicado el: 2026-11-04

CVE-2026-121933

Descripción: A flaw has been found in Linksys E5350 1.0.00.037. This impacts the function save_settings of the file /wizard/apply.cgi of the component Setup Wizard. Executing a manipulation of the argument wizard_router_pwd can lead to missing authentication. The attack may be launched remotely. The exploit has been published and may be used. The vendor was contacted early about this disclosure but did not ...

CVSS: 10.0 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:H

Tipo: CWE-287

Tecnología: No especificado

Publicado el: 2026-11-04

CVE-2026-122013

Descripción: A vulnerability was detected in Comfast CF-WR632AX 2.6.0.1. Affected by this vulnerability is an unknown functionality of the file /usr/bin/webmgnt of the component Multipart Parser. Performing a manipulation of the argument filename results in path traversal. It is possible to initiate the attack remotely. The exploit is now public and may be used. The vendor was contacted early about this dis...

CVSS: 10.0 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:H

Tipo: CWE-22

Tecnología: No especificado

Publicado el: 2026-11-04

CVE-2026-82418

Descripción: IBM Watson Speech Services Cartridge 4.0.0 through 5.4.0 could allow a remote attacker to execute arbitrary code due to a use-after-free vulnerability.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-416

Tecnología: No especificado

Publicado el: 2026-11-04

CVE-2026-54378

Descripción: VitaFit cloud API before 2026-10-30 contained a broken access control vulnerability that allows any authenticated user to obtain temporary AWS credentials by calling the POST /front/user/s3/token/ endpoint. Attackers can use these improperly scoped credentials to list the shared storage bucket and read or overwrite other users' stored files, enabling unauthorized cross-user data access and mani...

CVSS: 9.6 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:C/C:H/I:H/A:N

Tipo: CWE-522

Tecnología: No especificado

Publicado el: 2026-11-04

CVE-2026-54384

Descripción: VitaFit cloud API before 2026-10-30 contained an authentication bypass vulnerability that allows remote attackers to obtain a full session for a victim's account by submitting a linked Google or Facebook account identifier to the POST /front/login/sns/ endpoint without providing proof of ownership from the identity provider. Attackers can forge a login using an identifier exposed through accoun...

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-290

Tecnología: No especificado

Publicado el: 2026-11-04

CVE-2026-122302

Descripción: Kyverno before 1.19.2 contains a privilege escalation vulnerability that allows namespace admins to create resources beyond their RBAC because generate-rule admission checks verify the controller's permissions, not the author's. Attackers can create a namespaced Policy with generate rules targeting other namespaces or cluster-scoped kinds, making the background controller create or clone resour...

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-269

Tecnología: No especificado

Publicado el: 2026-11-05



CVE-2026-122303

Descripción: Kyverno from 1.17.0 before 1.19.2 contains an authorization bypass vulnerability that allows namespace tenants to overwrite resources in other namespaces via NamespacedMutatingPolicy mutate-existing targetMatchConstraints.expression. Attackers can return a CEL map literal fabricating a target with an attacker-chosen metadata.namespace, causing the privileged background controller to overwrite S...

CVSS: 9.9 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:C/C:H/I:H/A:H

Tipo: CWE-862

Tecnología: No especificado

Publicado el: 2026-11-05

CVE-2026-122304

Descripción: Kyverno from 1.17.0 before 1.19.2 contains an authorization bypass vulnerability that allows namespace admins to escape namespace confinement because the cleanup controller builds its context loader with a nil policy. Attackers can create a namespaced CleanupPolicy with apiCall or globalReference context entries to read cross-namespace Secrets and modify validatingwebhookconfigurations using th...

CVSS: 9.9 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:C/C:H/I:H/A:H

Tipo: CWE-863

Tecnología: No especificado

Publicado el: 2026-11-05



CVE-2026-122310

Descripción: Kyverno from 1.19.1 before 1.19.2 validates a Policy's context.apiCall urlPath after cleaning it but executes the raw path, whose fragment or query the Kubernetes client discards. A namespace-scoped user who can create a Policy can hide ../ segments behind # or ? to reach cluster-scoped endpoints with Kyverno's ServiceAccount, gaining cluster admin.

CVSS: 9.9 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:C/C:H/I:H/A:H

Tipo: CWE-436

Tecnología: No especificado

Publicado el: 2026-11-05

CVE-2026-122311

Descripción: Kyverno from 1.16.0 before 1.19.2 fails to validate path segments in the resource argument of resource.get() and resource.post(), allowing namespaced CEL policies to escape their namespace. Tenants who can create a NamespacedValidatingPolicy can insert .. segments to read and write arbitrary cluster objects using the admission controller's ServiceAccount, leading to cluster takeover.

CVSS: 9.9 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:C/C:H/I:H/A:H

Tipo: CWE-22

Tecnología: No especificado

Publicado el: 2026-11-05

CVE-2026-122313

Descripción: Kyverno from 1.17.0 before 1.19.2 contains a privilege escalation vulnerability that allows namespace-scoped tenants to modify resources in other namespaces through NamespacedMutatingPolicy targetMatchConstraints.expression CEL output lacking namespace checks. Attackers can emit a literal target such as another tenant's RoleBinding, which the cluster-wide background controller then mutates to a...

CVSS: 9.9 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:C/C:H/I:H/A:H

Tipo: CWE-269

Tecnología: No especificado

Publicado el: 2026-11-05

CVE-2026-122321

Descripción: Kyverno 1.18.0 before 1.19.2 contains a signature verification bypass in verifyImages because cached verification results are keyed by the image reference string (such as a tag) rather than bound to the verified digest, so cache hits skip signature and attestation checks. An attacker who can submit workloads and move a registry tag can warm the cache with a signed image, repoint the tag, and ha...

CVSS: 9.1 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:C/C:L/I:H/A:L

Tipo: CWE-367

Tecnología: No especificado

Publicado el: 2026-11-05

CVE-2026-119757

Descripción: BTCPay Server before 2.4.2, including 2.4.2 release candidates, contains an information disclosure vulnerability that allows unauthenticated remote attackers to retrieve .macaroon credential files for an LND (Lightning Network Daemon) node. Attackers can use the exposed macaroon to gain full control of the LND node, including moving funds, resulting in theft of funds from affected deployments.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-522

Tecnología: No especificado

Publicado el: 2026-11-05

CVE-2026-123488

Descripción: Craft CMS 4.0.0 before 4.18.9 and 5.0.0 before 5.11.2 contains an unauthenticated SQL injection vulnerability in the element search endpoint because the attribute parameter is concatenated into the query unsanitized and emulated PDO prepares allow stacked statements. Remote attackers can read and write the database, setting the admin flag or overwriting password hashes in the users table to gai...

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-89

Tecnología: No especificado

Publicado el: 2026-11-06

CVE-2026-109469

Descripción: Authorization bypass through user-controlled key in Entra Device Registration allows an unauthorized attacker to elevate privileges over a network.

CVSS: 10.0 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:H

Tipo: CWE-639

Tecnología: No especificado

Publicado el: 2026-11-06

CVE-2026-93754

Descripción: The payever – WooCommerce Gateway plugin for WordPress is vulnerable to arbitrary file upload leading to remote code execution in various versions up to, and including, 4.8.0. Three WooCommerce-API callbacks (payever_set_sandbox_api_keys, payever_toggle_subscription, payever_synchronization_incoming) are registered with no authentication, capability check, or nonce, and the upload_image() routi...

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-434

Tecnología: No especificado

Publicado el: 2026-11-07

CVE-2026-123218

Descripción: IBM Aspera Faspex 5.0.0 through 5.0.19 could allow an authorized user to craft a specific message to bypass user authorization and gain full administrative privileges.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-863

Tecnología: No especificado

Publicado el: 2026-11-07

CVE-2026-19803

Descripción: The Printcart Store – Web to Print Product Designer for WooCommerce plugin for WordPress is vulnerable to Arbitrary File Upload in all versions up to, and including, 2.13.2. This is due to the `nbu_crop_image` AJAX handler accepting a user-supplied `url` parameter that `Nbdesigner_IO::convert_url_to_path()` concatenates onto the uploads base directory without normalizing or stripping `../` sequ...

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-94

Tecnología: No especificado

Publicado el: 2026-11-07

CVE-2026-16720

Descripción: IBM API Connect 10.0.8.0 through 10.0.8.12 and 12.1.0.0 through 12.1.1.2 could allow a remote attacker to obtain valid access tokens for other users due to improper authentication. Authentication against a connected directory service is not sufficiently enforced, which could allow another user's identity to be assumed.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-287

Tecnología: No especificado

Publicado el: 2026-11-07

CVE-2026-16884

Descripción: IBM API Connect 12.1.0.0 through 12.1.1.2 could allow a remote attacker to obtain sensitive information due to an XML external entity (XXE) injection.

CVSS: 9.9 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:L/A:L

Tipo: CWE-611

Tecnología: No especificado

Publicado el: 2026-11-07

CVE-2026-16918

Descripción: IBM API Connect 10.0.8.0 through 10.0.8.12 and 12.1.0.0 through 12.1.1.2 could allow a remote attacker to access internal network resources due to server-side request forgery.

CVSS: 9.3 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:L/A:N

Tipo: CWE-918

Tecnología: No especificado

Publicado el: 2026-11-07

CVE-2026-16920

Descripción: IBM API Connect 12.1.0.0 through 12.1.1.2 could allow a remote authenticated attacker to bypass security restrictions due to a confused deputy vulnerability.

CVSS: 9.9 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:C/C:H/I:H/A:H

Tipo: CWE-441

Tecnología: No especificado

Publicado el: 2026-11-07

CVE-2026-17049

Descripción: IBM API Connect 12.1.0.0 through 12.1.1.2 could allow a remote authenticated attacker to obtain sensitive information and modify arbitrary documents due to authorization bypass through user-controlled keys.

CVSS: 9.9 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:C/C:H/I:H/A:H

Tipo: CWE-639

Tecnología: No especificado

Publicado el: 2026-11-07

CVE-2026-17066

Descripción: IBM API Connect 12.1.0.0 through 12.1.1.2 could allow a remote authenticated attacker to obtain sensitive information and modify or delete data belonging to other tenants due to missing authorization.

CVSS: 9.1 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:H/UI:N/S:C/C:H/I:H/A:H

Tipo: CWE-862

Tecnología: No especificado

Publicado el: 2026-11-07

CVE-2026-17117

Descripción: IBM API Connect 10.0.8.0 through 10.0.8.12 and 12.1.0.0 through 12.1.1.2 could allow a remote authenticated attacker to execute arbitrary code due to improperly controlled modification of object attributes. A user could set a field that should only be controlled by the system, which could lead to code execution.

CVSS: 9.9 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:C/C:H/I:H/A:H

Tipo: CWE-915

Tecnología: No especificado

Publicado el: 2026-11-07

CVE-2026-17131

Descripción: IBM API Connect 12.1.0.0 through 12.1.1.2 could allow a remote attacker to obtain sensitive information due to server-side request forgery. Restrictions on outbound requests can be bypassed, so the server could be made to contact unintended destinations and return the response.

CVSS: 9.3 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:L/A:N

Tipo: CWE-918

Tecnología: No especificado

Publicado el: 2026-11-07

CVE-2026-17132

Descripción: IBM API Connect 12.1.0.0 through 12.1.1.2 could allow a remote authenticated attacker to execute arbitrary SQL commands due to improper neutralization of special elements used in an SQL command.

CVSS: 9.9 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:C/C:H/I:H/A:H

Tipo: CWE-89

Tecnología: No especificado

Publicado el: 2026-11-07

CVE-2026-17134

Descripción: IBM API Connect 12.1.0.0 through 12.1.1.2 could allow a remote authenticated attacker to execute arbitrary SQL commands due to SQL injection.

CVSS: 9.9 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:C/C:H/I:H/A:L

Tipo: CWE-89

Tecnología: No especificado

Publicado el: 2026-11-07

CVE-2026-17146

Descripción: IBM API Connect 10.0.8.0 through 10.0.8.12 and 12.1.0.0 through 12.1.1.2 could allow a remote authenticated attacker to execute arbitrary JavaScript and obtain sensitive information due to improper input validation.

CVSS: 9.9 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:C/C:H/I:H/A:H

Tipo: CWE-79

Tecnología: No especificado

Publicado el: 2026-11-07

CVE-2026-17147

Descripción: IBM API Connect 10.0.8.0 through 10.0.8.12 and 12.1.0.0 through 12.1.1.2 could allow a remote authenticated attacker to execute arbitrary code and perform unauthorized administrative actions due to a path traversal vulnerability.

CVSS: 9.9 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:C/C:H/I:H/A:H

Tipo: CWE-22

Tecnología: No especificado

Publicado el: 2026-11-07

CVE-2026-17150

Descripción: IBM API Connect 10.0.8.0 through 10.0.8.12 and 12.1.0.0 through 12.1.1.2 could allow a remote authenticated attacker to execute arbitrary code and access sensitive information from other tenants due to insufficient input validation. Uploaded custom module content is not sufficiently validated before it is processed, which could allow code to run with access beyond the user's own tenant.

CVSS: 9.9 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:C/C:H/I:H/A:H

Tipo: CWE-184

Tecnología: No especificado

Publicado el: 2026-11-07

CVE-2026-17158

Descripción: IBM API Connect 10.0.8.0 through 10.0.8.12 and 12.1.0.0 through 12.1.1.2 could allow a remote authenticated attacker to gain elevated privileges due to improper authentication.

CVSS: 9.9 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:C/C:H/I:H/A:H

Tipo: CWE-287

Tecnología: No especificado

Publicado el: 2026-11-07

CVE-2026-17239

Descripción: IBM API Connect 12.1.0.0 through 12.1.1.2 could allow a remote authenticated attacker to execute arbitrary code due to a path traversal vulnerability.

CVSS: 9.9 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:C/C:H/I:H/A:H

Tipo: CWE-22

Tecnología: No especificado

Publicado el: 2026-11-07

CVE-2026-17278

Descripción: IBM API Connect 12.1.0.0 through 12.1.1.2 could allow a remote attacker to gain unauthorized access to sensitive API catalog and runtime configuration data due to improper authentication. Information supplied by the client is not sufficiently verified, which could allow a caller to appear as a trusted party.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-290

Tecnología: No especificado

Publicado el: 2026-11-07

CVE-2026-17292

Descripción: IBM API Connect 10.0.8.0 through 10.0.8.12 and 12.1.0.0 through 12.1.1.2 could allow a remote authenticated attacker to take over ownership of other organizations due to broken object-level authorization. Access checks on organization objects are incomplete, which could allow ownership of organizations the user does not control to be changed.

CVSS: 9.1 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:C/C:L/I:H/A:L

Tipo: CWE-639

Tecnología: No especificado

Publicado el: 2026-11-07

CVE-2026-17296

Descripción: IBM API Connect 10.0.8.0 through 10.0.8.12 and 12.1.0.0 through 12.1.1.2 could allow a remote authenticated attacker to obtain sensitive information due to server-side request forgery.

CVSS: 9.6 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:C/C:H/I:H/A:N

Tipo: CWE-918

Tecnología: No especificado

Publicado el: 2026-11-07

CVE-2026-17297

Descripción: IBM API Connect 10.0.8.0 through 10.0.8.12 and 12.1.0.0 through 12.1.1.2 could allow a remote attacker to perform an account takeover due to an open redirect vulnerability. The redirect address used during sign-in is not sufficiently validated, which could allow authentication results to be sent to an attacker-controlled location.

CVSS: 9.6 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:C/C:H/I:H/A:H

Tipo: CWE-601

Tecnología: No especificado

Publicado el: 2026-11-07

CVE-2026-17298

Descripción: IBM API Connect 10.0.8.0 through 10.0.8.12 and 12.1.0.0 through 12.1.1.2 could allow a remote authenticated attacker to obtain sensitive information due to server-side request forgery.

CVSS: 9.9 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:C/C:H/I:H/A:H

Tipo: CWE-918

Tecnología: No especificado

Publicado el: 2026-11-07

CVE-2026-17299

Descripción: IBM API Connect 10.0.8.0 through 10.0.8.12 and 12.1.0.0 through 12.1.1.2 could allow a remote authenticated attacker to perform arbitrary file reads and server-side request forgery due to unrestricted resolution of external references. Externally referenced content in submitted definitions is not sufficiently restricted when processed, and the retrieved content could be returned to the attacker.

CVSS: 9.6 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:C/C:H/I:H/A:N

Tipo: CWE-918

Tecnología: No especificado

Publicado el: 2026-11-07

CVE-2026-17301

Descripción: IBM API Connect 10.0.8.0 through 10.0.8.12 and 12.1.0.0 through 12.1.1.2 could allow an unauthenticated attacker to bypass authentication due to improper verification of a cryptographic signature.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-347

Tecnología: No especificado

Publicado el: 2026-11-07

CVE-2026-17313

Descripción: IBM API Connect 12.1.0.0 through 12.1.1.2 could allow a remote attacker to obtain sensitive information and take control of gateway configuration due to authentication bypass via an alternate path.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-288

Tecnología: No especificado

Publicado el: 2026-11-07

CVE-2026-17329

Descripción: IBM API Connect 12.1.0.0 through 12.1.1.2 could allow a remote attacker to obtain sensitive information due to improper validation of endpoint URLs.

CVSS: 9.3 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:L/A:N

Tipo: CWE-918

Tecnología: No especificado

Publicado el: 2026-11-07

CVE-2026-17336

Descripción: IBM API Connect 12.1.0.0 through 12.1.1.2 could allow a remote authenticated attacker to execute arbitrary SQL commands due to improper neutralization of special elements used in an SQL command.

CVSS: 9.9 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:C/C:H/I:H/A:H

Tipo: CWE-89

Tecnología: No especificado

Publicado el: 2026-11-07

CVE-2026-17338

Descripción: IBM API Connect 12.1.0.0 through 12.1.1.2 could allow a remote authenticated attacker to obtain sensitive information due to broken object-level authorization.

CVSS: 9.1 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:C/C:H/I:L/A:L

Tipo: CWE-639

Tecnología: No especificado

Publicado el: 2026-11-07

CVE-2026-17339

Descripción: IBM API Connect 12.1.0.0 through 12.1.1.2 could allow a remote authenticated attacker to access or delete resources belonging to other tenants due to path traversal.

CVSS: 9.1 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:C/C:L/I:H/A:L

Tipo: CWE-22

Tecnología: No especificado

Publicado el: 2026-11-07

CVE-2026-17340

Descripción: IBM API Connect 12.1.0.0 through 12.1.1.2 could allow a remote attacker to execute arbitrary code due to a path traversal vulnerability.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-22

Tecnología: No especificado

Publicado el: 2026-11-07

CVE-2026-17342

Descripción: IBM API Connect 10.0.8.0 through 10.0.8.12 and 12.1.0.0 through 12.1.1.2 could allow a remote authenticated attacker to execute arbitrary code due to improper control of generation of code.

CVSS: 9.9 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:C/C:H/I:H/A:H

Tipo: CWE-94

Tecnología: No especificado

Publicado el: 2026-11-07

CVE-2026-17344

Descripción: IBM API Connect 12.1.0.0 through 12.1.1.2 could allow a remote attacker to obtain sensitive information due to server-side request forgery. A service that can be reached without authentication could be made to send requests to unintended destinations.

CVSS: 9.3 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:L/A:N

Tipo: CWE-918

Tecnología: No especificado

Publicado el: 2026-11-07

CVE-2026-17353

Descripción: IBM API Connect 12.1.0.0 through 12.1.1.2 could allow a remote authenticated attacker to obtain sensitive information and bypass security restrictions due to server-side request forgery.

CVSS: 9.6 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:C/C:H/I:H/A:N

Tipo: CWE-918

Tecnología: No especificado

Publicado el: 2026-11-07

CVE-2026-17354

Descripción: IBM API Connect 12.1.0.0 through 12.1.1.2 could allow a remote authenticated attacker to perform arbitrary file writes due to path traversal.

CVSS: 9.9 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:C/C:H/I:H/A:H

Tipo: CWE-22

Tecnología: No especificado

Publicado el: 2026-11-07

CVE-2026-17359

Descripción: IBM API Connect 10.0.8.0 through 10.0.8.12 and 12.1.0.0 through 12.1.1.2 could allow a remote authenticated attacker to execute arbitrary code due to improper control of generation of code. A user-supplied value can influence code that the product generates, which could lead to code execution.

CVSS: 9.9 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:C/C:H/I:H/A:H

Tipo: CWE-94

Tecnología: No especificado

Publicado el: 2026-11-07

CVE-2026-17360

Descripción: IBM API Connect 12.1.0.0 through 12.1.1.2 could allow a remote attacker to gain full administrative control due to the use of hard-coded credentials.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-798

Tecnología: No especificado

Publicado el: 2026-11-07

CVE-2026-17392

Descripción: IBM API Connect 10.0.8.0 through 10.0.8.12 and 12.1.0.0 through 12.1.1.2 could allow a remote authenticated attacker to gain unauthorized administrative access to other tenants due to LDAP injection. User-supplied input is not properly neutralized in directory queries, which could change the query and grant access beyond the user's own tenant.

CVSS: 9.9 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:C/C:H/I:H/A:H

Tipo: CWE-90

Tecnología: No especificado

Publicado el: 2026-11-07

CVE-2026-17394

Descripción: IBM API Connect 10.0.8.0 through 10.0.8.12 and 12.1.0.0 through 12.1.1.2 could allow a remote authenticated attacker to obtain sensitive information due to improperly controlled modification of object attributes. A user-supplied value could change an access-related setting that should be controlled by the system, which could expose sensitive information.

CVSS: 9.6 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:C/C:H/I:H/A:N

Tipo: CWE-915

Tecnología: No especificado

Publicado el: 2026-11-07

CVE-2026-17396

Descripción: IBM API Connect 10.0.8.0 through 10.0.8.12 and 12.1.0.0 through 12.1.1.2 could allow a remote authenticated attacker to obtain sensitive information due to SQL injection.

CVSS: 9.6 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:C/C:H/I:H/A:N

Tipo: CWE-89

Tecnología: No especificado

Publicado el: 2026-11-07

CVE-2026-17399

Descripción: IBM API Connect 10.0.8.0 through 10.0.8.12 and 12.1.0.0 through 12.1.1.2 could allow a remote authenticated attacker to execute arbitrary code due to insufficient validation of uploaded content. Content uploaded to the product is not sufficiently checked before it is processed, which could allow code to run on the server.

CVSS: 9.9 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:C/C:H/I:H/A:H

Tipo: CWE-434

Tecnología: No especificado

Publicado el: 2026-11-07

CVE-2026-17402

Descripción: IBM API Connect 10.0.8.0 through 10.0.8.12 and 12.1.0.0 through 12.1.1.2 could allow a remote authenticated attacker to execute arbitrary commands due to OS command injection. User-supplied input is not properly neutralized before it is passed to the operating system, which could allow commands to run on the underlying host.

CVSS: 9.9 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:C/C:H/I:H/A:H

Tipo: CWE-78

Tecnología: No especificado

Publicado el: 2026-11-07

CVE-2026-17403

Descripción: IBM API Connect 10.0.8.0 through 10.0.8.12 and 12.1.0.0 through 12.1.1.2 could allow a remote attacker to gain full administrative control due to the use of hard-coded credentials.

CVSS: 9.0 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:C/C:H/I:H/A:H

Tipo: CWE-798

Tecnología: No especificado

Publicado el: 2026-11-07

CVE-2026-17408

Descripción: IBM API Connect 10.0.8.0 through 10.0.8.12 and 12.1.0.0 through 12.1.1.2 could allow a remote attacker to execute arbitrary code due to improper neutralization of special elements in an OS command.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-78

Tecnología: No especificado

Publicado el: 2026-11-07

CVE-2026-17409

Descripción: IBM API Connect 10.0.8.0 through 10.0.8.12 and 12.1.0.0 through 12.1.1.2 could allow a remote attacker to execute unauthorized administrative operations and obtain sensitive information due to improper handling of case sensitivity. Access controls are not applied consistently to all variations of a request, which could allow restricted operations to be reached.

CVSS: 9.4 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:H/A:H

Tipo: CWE-178

Tecnología: No especificado

Publicado el: 2026-11-07

CVE-2026-17410

Descripción: IBM API Connect 10.0.8.0 through 10.0.8.12 and 12.1.0.0 through 12.1.1.2 could allow a remote authenticated attacker to access and modify other tenants' portal data due to improper neutralization of argument delimiters.

CVSS: 9.9 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:C/C:H/I:H/A:H

Tipo: CWE-88

Tecnología: No especificado

Publicado el: 2026-11-07

CVE-2026-18535

Descripción: IBM API Connect 10.0.8.0 through 10.0.8.12 and 12.1.0.0 through 12.1.1.2 are vulnerable to a Regular Expression Denial of Service (ReDoS) attack and to improper neutralisation of wildcard query operators.

CVSS: 9.6 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:C/C:H/I:N/A:H

Tipo: CWE-1333

Tecnología: No especificado

Publicado el: 2026-11-07

CVE-2026-18836

Descripción: IBM API Connect 10.0.8.0 through 10.0.8.12 and 12.1.0.0 through 12.1.1.2 could allow a remote attacker to obtain sensitive information due to server-side request forgery. The affected component can be made to send requests to unintended destinations and return the response to the attacker.

CVSS: 9.3 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:C/C:L/I:H/A:N

Tipo: CWE-918

Tecnología: No especificado

Publicado el: 2026-11-07

CVE-2026-18838

Descripción: IBM API Connect 12.1.0.0 through 12.1.1.2 could allow a remote attacker to obtain sensitive information and modify API configurations due to improper authentication. Identity information supplied in requests is not sufficiently verified, which could allow a caller to impersonate another user.

CVSS: 9.4 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:L

Tipo: CWE-290

Tecnología: No especificado

Publicado el: 2026-11-07

CVE-2026-123957

Descripción: A vulnerability was determined in TOTOLINK CA300-PoE 6.2c.884. Impacted is the function setIpQosRules of the file /cgi-bin/cstecgi.cgi. This manipulation of the argument ipStart causes buffer overflow. It is possible to initiate the attack remotely.
The exploit has been publicly disclosed and may be utilized.

CVSS: 9.9 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:C/C:H/I:H/A:H

Tipo: CWE-119

Tecnología: No especificado

Publicado el: 2026-11-07

CVE-2026-123958

Descripción: A vulnerability was identified in TOTOLINK CA300-PoE 6.2c.884. The affected element is the function setLanConfig of the file /cgi-bin/cstecgi.cgi. Such manipulation of the argument lanDns/lanSecDns/langType leads to buffer overflow. It is possible to launch the attack remotely. The exploit is publicly available and might be used.

CVSS: 9.9 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:C/C:H/I:H/A:H

Tipo: CWE-119

Tecnología: No especificado

Publicado el: 2026-11-07

CVE-2026-123959

Descripción: A security flaw has been discovered in TOTOLINK CA300-PoE 6.2c.884. The impacted element is the function setLanguageCfg of the file /cgi-bin/cstecgi.cgi. Performing a manipulation of the argument langType results in buffer overflow. The attack can be initiated remotely. The exploit has been released to the public and may be used for attacks.

CVSS: 9.1 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:H/UI:N/S:C/C:H/I:H/A:H

Tipo: CWE-119

Tecnología: No especificado

Publicado el: 2026-11-07

CVE-2026-123960

Descripción: A weakness has been identified in TOTOLINK CA300-PoE 6.2c.884. This affects the function setWanConfig of the file /cgi-bin/cstecgi.cgi. Executing a manipulation of the argument pppoeUser/priDns/secDns can lead to buffer overflow. The attack can be launched remotely. The exploit has been made available to the public and could be used for attacks.

CVSS: 9.9 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:C/C:H/I:H/A:H

Tipo: CWE-119

Tecnología: No especificado

Publicado el: 2026-11-07

CVE-2026-123961

Descripción: A security vulnerability has been detected in TOTOLINK CA300-PoE 6.2c.884. This impacts the function setWiFiBasicConfig of the file /cgi-bin/cstecgi.cgi. The manipulation of the argument KeyStr leads to buffer overflow. The attack may be initiated remotely. The exploit has been disclosed publicly and may be used.

CVSS: 9.9 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:C/C:H/I:H/A:H

Tipo: CWE-119

Tecnología: No especificado

Publicado el: 2026-11-07

CVE-2026-104014

Descripción: The Naimur Email OTP Verification for WooCommerce plugin for WordPress is vulnerable to authentication bypass in versions up to, and including, 2.1.0. This is due to the plugin's password-reset finalization endpoint (the wp_ajax_nopriv_ceovw_update_new_password action handled by CEOVW_AJAX::update_new_password()) authorizing the reset solely by the presence of a database row marking an email as...

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-287

Tecnología: No especificado

Publicado el: 2026-11-07

CVE-2026-118066

Descripción: The Appointment Booking Plugin – LatePoint | Calendar & Scheduling for WordPress plugin for WordPress is vulnerable to Authentication Bypass via Account Takeover in all versions up to, and including, 5.7.6. This is due to the `OsModel::build_conditions_query()` function in `lib/models/model.php` comparing WHERE-clause values against the literal strings "IS NULL" and "IS NOT NULL" and concat...

CVSS: 9.1 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:N

Tipo: CWE-287

Tecnología: No especificado

Publicado el: 2026-11-07

CVE-2026-119075

Descripción: The Registration Form for WooCommerce plugin for WordPress is vulnerable to privilege escalation due to a missing allow-list check in the FormHandler::validate_checkout_fields() function in versions up to, and including, 1.1.4 The My Account registration path (validate_fields()) validates a submitted 'tgwcfb/user-roles' value against the form's configured allowed roles, but the checkout registr...

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-269

Tecnología: No especificado

Publicado el: 2026-11-07

CVE-2026-122041

Descripción: The Checkout Field Editor for WooCommerce (Pro) plugin for WordPress is vulnerable to unauthorized deletion of arbitrary attachments due to a missing capability/ownership check in the ajax_remove_uploaded() function in versions up to, and including, 3.8.0. The handler is registered for both wp_ajax and wp_ajax_nopriv and is gated solely by the 'file_handling_nonce' nonce, which is emitted insid...

CVSS: 9.1 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:H/A:H

Tipo: CWE-862

Tecnología: No especificado

Publicado el: 2026-11-07

CVE-2026-120984

Descripción: A flaw was found in the Keycloak server's client management component. When a client is created or imported with authorization services enabled, the system fails to properly clear an internal session attribute used during the setup process. This allows an authenticated attacker with client management permissions to bypass security controls and upload a malicious JavaScript policy, which is then...

CVSS: 9.1 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:H/UI:N/S:C/C:H/I:H/A:H

Tipo: CWE-94

Tecnología: No especificado

Publicado el: 2026-11-07

CVE-2026-123966

Descripción: A vulnerability was determined in Tenda AC19 16.03.10.07. Affected by this issue is the function saveParentControlInfo of the file /goform/saveParentControlInfo. This manipulation of the argument deviceId causes heap-based buffer overflow. The attack is possible to be carried out remotely. The exploit has been publicly disclosed and may be utilized.

CVSS: 10.0 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:H

Tipo: CWE-119

Tecnología: No especificado

Publicado el: 2026-11-07

Resumen del Reporte

CVEs analizados: 85

Promedio CVSS: 9.70

Fuente: nvd.nist.gov

Nos vemos la próxima semana. Hack the Cat

